

NOMBRE: ENYA NAOMI MIRANDA FLORES FECHA: 5 DE SEPTIEMBRE DEL 2026

ESCENARIO DE AURORA MARKET (Contexto del caso y del incidente reportado)

Aurora Market es una plataforma mexicana de comercio electrónico que ha experimentado un crecimiento acelerado en los últimos años. Comenzó como un comercio pequeño enfocado en la venta de productos tecnológicos mediante redes sociales y evolucionó hasta convertirse en una plataforma web consolidada.

Durante este proceso de expansión, **Aurora Market ha recopilado e integrado información altamente sensible de sus clientes.** Hace algunas semanas, el área de Atención al Cliente de Aurora Market **recibió una notificación crítica por parte de un usuario final, quien afirmó haber tenido acceso visible a información sensible que pertenecía a la cuenta de otro cliente.**

Ante esta alerta, **el equipo técnico de la empresa llevó a cabo una revisión inicial** de la infraestructura; sin embargo, **no fue posible determinar la causa raíz** ya que no pudieron confirmar si se trataba de un error de la aplicación, una configuración incorrecta, un fallo de permisos o una vulnerabilidad de seguridad real. Ante la falta de evidencia suficiente para confirmar un ataque, **la dirección de Aurora Market planteó una duda fundamental: ¿Qué tan segura es realmente nuestra aplicación?**

Nunca se ha ejecutado una evaluación integral de seguridad técnica sobre la plataforma. Por ello decidieron contratar un equipo especializado en Ethical Hacking y Penetration Testing

ANALISIS Y PLANIFICACIÓN DEL PENTEST

- 1) **Objetivo General:** Evaluar la seguridad de la aplicación web de Aurora Market para descubrir qué tan expuesta está a posibles ataques, identificando sus puntos débiles para ayudar a la empresa a corregirlos y proteger la información de sus clientes.

Objetivos Específicos:

- **Investigar el incidente reportado:** Averiguar por qué ocurrió la falla donde un cliente pudo ver información de otra cuenta, revisando cómo la página maneja los inicios de sesión y los permisos de usuario.
- **Evaluar las funciones clave de la plataforma:** Probar las secciones principales de la tienda (como el catálogo, el carrito de compras, el proceso de pago) para encontrar otras fallas de seguridad.
- **Entregar un plan de solución claro:** Presentar a Aurora Market una lista con los problemas encontrados y como el equipo de desarrollo puede corregirlos.

2) ALCANCE

Dentro del alcance:

- Aplicación web oficial de Aurora Market (módulos o secciones de registro/login, gestión de perfil, catálogo, carrito de compras, historial de pedidos).

Fuera del alcance:

- Redes sociales de la empresa.
- Dispositivos/equipos personales de los empleados.
- Cuentas de correo electrónico corporativo o personal.
- Proveedores externos de servicios e infraestructura fuera de la plataforma web.

3) Autorización, Permisos y Condiciones Acordadas

- **Disponibilidad operativa:** Se prohíbe cualquier acción que pueda interrumpir el funcionamiento de la plataforma o que altere y comprometa la información real de los clientes.
- **Horarios:** Las pruebas técnicas se realizarán únicamente en horarios con menor actividad operativa para minimizar cualquier impacto sobre sus operaciones.
- **Permisos y Marco de Colaboración:** El equipo cuenta con la autorización formal por escrito de Aurora Market.

4) TIPO DE PENTEST SELECCIONADO: GRAY-BOX (CAJA GRIS).

Justificación: Aurora Market proporciona información parcial de la aplicación web, base de datos, mecanismos de autenticación y roles, pero no otorga la arquitectura completa. Esta modalidad simula la perspectiva de un atacante con conocimientos previos limitados ya que Aurora Market quiere saber que podría obtener un atacante basándose únicamente en la información disponible.

5) PLANIFICACIÓN

1. Objetivo: Confirmar los objetivos y alcances del pentest con el equipo de Aurora Market para asegurar y proteger la información de sus clientes.

2. Alcance: Confirmar los módulos o secciones de la app web que serán evaluados, asegurando que los sistemas externos queden excluidos.

A partir del escenario de **Aurora Market**, desarrolla los siguientes puntos.

3. Permisos y Condiciones: Delimitar formalmente los horarios en los que se trabajara en la app web para su evaluación.

4. Metodología a Utilizar: Podemos utilizar **PTES** para estructurar la gestión general del proyecto y asegurar que cubrimos todas las fases, mientras empleamos los recursos y guías de **OWASP** para profundizar técnicamente en la evaluación específica de una aplicación web.

5. Recopilación de Información Previa: Solicitar la información técnica básica disponible sobre la app web y revisar el reporte del incidente inicial.

6. Recursos Necesarios:

- **Burp Suite / OWASP ZAP:** Para interceptar y analizar el tráfico de la plataforma web, evaluando fallas en la autenticación, el carrito y los permisos entre cuentas.
- **Nmap:** Para identificar los puertos abiertos y servicios activos en el servidor que aloja a Aurora Market.
- **Shodan y traceroute:** Como apoyo para verificar la exposición y ruta de red hacia el servidor de la empresa.
- **Creación de cuentas** de usuario de prueba.

7. Programación del Pentest: Definir el tiempo por cada fase y establecer el canal directo para reportar hallazgos críticos.

6) FASES DEL PENTEST

1. Reconocimiento: Exploramos la página web para ver qué tecnología usa, mapeamos las secciones como el catálogo, el inicio de sesión y el carrito, y revisamos qué servicios tiene públicos en internet.

2. Análisis de vulnerabilidades: Usamos Burp Suite aquí buscamos la falla clave ver si el sistema permite cambiar el número o nombre de usuario para intentar ver la cuenta de otra persona.

3. Explotación: Crear dos cuentas de prueba, intentar desde la Cuenta A ver las compras o datos personales de la Cuenta B. También probar si se pueden modificar los precios en el carrito de compras o saltarse el inicio de sesión.

A partir del escenario de **Aurora Market**, desarrolla los siguientes puntos.

4. Post-Explotación: Evaluar qué datos de los clientes habrían quedado expuestos (direcciones, historial de compras, correos) y tomamos capturas de pantalla como evidencia sin alterar la base de datos real.

5. Informe: Crear un informe dirigido a la gerencia, explicando lo que se encontró el nivel de riesgo e impacto potencial al negocio en un lenguaje sencillo y otro informe técnico dirigido al equipo de desarrollo, detallando cada vulnerabilidad

7) INVESTIGACIÓN: OWASP WSTG combinada con PTES.

OWASP nos ayuda para el análisis y planificación del pentest de Aurora Market ya que es una técnica experta en páginas web tiene pasos específicos y recursos para buscar fallas pues dispone de listas de chequeo diseñadas para evaluar cada parte clave de la página web: el inicio de sesión, el carrito de compras, los pagos y el panel de administración. Esto ayuda a detectar exactamente por qué un cliente de Aurora Market podría estar viendo los datos de otra persona.

Por otra parte, **PTES** también nos ayuda porque es una metodología de gestión, es decir, que organiza el proyecto completo por etapas o fases (contrato/permisos, pruebas, reportes) nos ayuda como guía en la evaluación de la página/ app web